Mandat, périmètre et niveau de confiance

Chloé, Nathan, Camille – BUT 3 Cybersécurité, UHA Colmar

QUESTION DE LA DIRECTION

« Quelles actions engager dans les 12 prochains mois pour réduire notre exposition à un arrêt de production cyber, structurer notre management de la sécurité et mieux répondre à nos donneurs d'ordre ? »

Périmètre

Bureautique, ERP, CAO, réseau industriel, postes d'ingénierie, SCADA, automates, accès distants prestataires, sauvegardes. SaaS RH : dépendance fournisseur seulement.

Méthode

16 pièces (E01-E16) et entretien simulé. ISO 27001 : clauses 4 à 10 et 15 contrôles de l'Annexe A. NIST CSF 2.0 : 25 résultats, profil actuel et cible.

Confiance : moyenne

Preuves documentaires cohérentes entre elles, mais pas de visite sur site. Surveillance physique et étendue de l'incident d'août 2026 non vérifiables.

Trois écarts critiques menacent la production

C1 Accès distant du prestataire non maîtrisé

Compte VPN partagé, sans MFA, parfois laissé actif ; 2 comptes admin SCADA partagés.

Preuve : E08 + entretien

Impact : Intrusion directe dans l'atelier, aucune traçabilité.

A.5.15-A.5.18 · PR.AA-01/03

C2 Pont ouvert entre l'IT et le SCADA

Règle pare-feu large du poste d'ingénierie (à jour à 60 %) vers le SCADA, alors que la DdA déclare la segmentation en place.

Preuve : E03, E07, E12

Impact : Un rançongiciel passe des bureaux aux automates.

A.8.22 · PR.IR-01, PR.PS-01

C3 Automates impossibles à restaurer

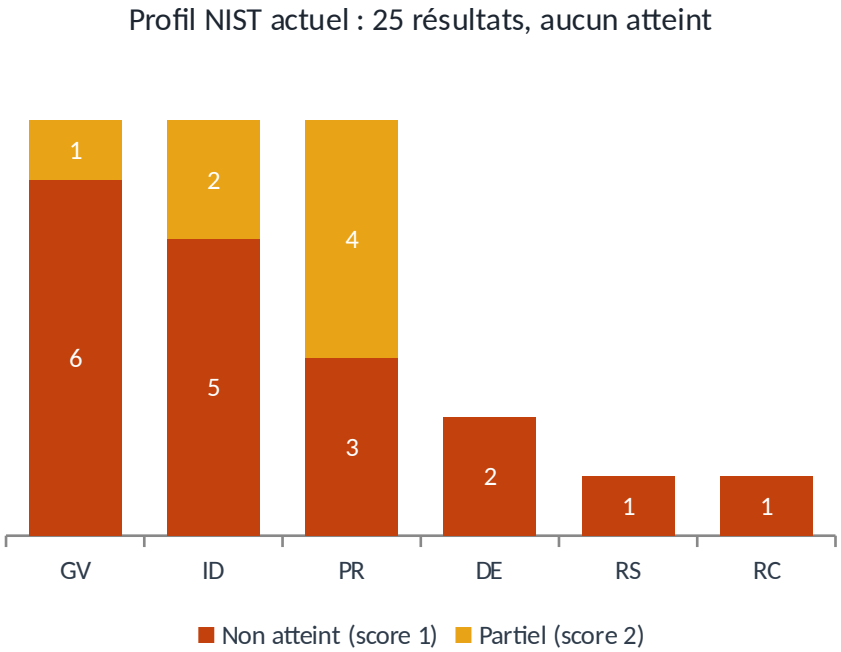
Configurations stockées uniquement sur le poste d'ingénierie, jamais testées en restauration.

Preuve : E09 + entretien

Impact : Arrêt long des lignes, livraisons clients en retard.

A.8.13, A.5.30 · PR.DS-11, RC.RP-01

ISO et NIST : les mêmes écarts, deux angles



Cible à 12 mois : score 3 (atteint) sur les 25 résultats. Échelle pédagogique de 0 à 4, distincte des Tiers.

ISO 27001 structure

Révèle le périmètre tronqué (E02), la DdA contredite par le réseau (E07/E03) et l'absence d'audit interne depuis 2023. Grille : 7 NC majeures, 1 mineure.

NIST CSF 2.0 communique

Montre l'état actuel et la cible par fonction ; sépare détecter, répondre et restaurer, essentiel pour l'OT. Tier 1 (Partiel) aujourd'hui, Tier 2 visé.

Ce qui converge

Accès distants, segmentation, sauvegardes OT, rôles : visibles dans les deux cadres. Les modèles fournis (CSF 1.1) ont été corrigés en CSF 2.0.

Cinq actions en trois phases sur douze mois



Quatre décisions attendues de la direction

1. **Nommer un responsable du risque cyber**
   Lettre de mission et autorité pour arbitrer entre IT et production.

2. **Valider les seuils d'acceptation du risque**
   Et une revue de direction trimestrielle avec KPI.

3. **Engager le budget par classe**
   S pour A1 et A4, M pour A2 et A3, L pour A5, à chiffrer.

4. **Imposer un avenant au prestataire d'automatisme**
   Comptes nominatifs, MFA, révocation, notification d'incident.

PROCHAINES ÉTAPES

M1 · responsable nommé, avenant engagé

M3 · MFA et comptes nominatifs en place

M6 · profil NIST réévalué, 1re revue avec KPI

M12 · audit interne, cible Tier 2 (Informé sur les risques)